

Course End Project-
Application Security, Vulnerability Management, and Cyber Resilience

**Conducting Vulnerability Assessment and Penetration Testing on a Simulated
Web Application Environment**

By

Sharmila Vijayan

1. Introduction:

Before releasing a web application, security testing is performed to identify and fix potential vulnerabilities. In this scenario, testers use **OWASP Juice Shop** deployed in a **Docker** container on **Kali Linux** to simulate real-world attacks in a safe environment. This allows them to detect issues like exposed endpoints, insecure files, and weak authentication mechanisms without risking actual user data.

2. Project Overview:

A development team plans to release a web application. Before the release, security testers assess a simulated version of the application by running OWASP Juice Shop in a Docker container on Kali Linux. The goal is to identify vulnerabilities that could expose sensitive information, such as misconfigured endpoints, insecure files, and weak authentication mechanisms. This safe environment allows testers to practice real-world penetration testing without putting actual user data at risk.

The testers document their findings and provide remediation recommendations to the development team. These include strengthening input validation, securing sensitive configuration files, hardening HTTP headers, and improving access controls. After implementing the fixes, the application undergoes additional testing to ensure improved security.

3. Project Objective:

To identify and assess security vulnerabilities in the web application using **OWASP Juice Shop**, provide remediation recommendations, and verify that implemented fixes improve overall application security before release.

4. Scope of the Project:

The scope of this project includes conducting a security assessment of a simulated web application using **OWASP Juice Shop** deployed in a **Docker** environment on **Kali Linux**.

The project covers:

- Open ports and http headers are verified using Nmap and curl respectively.
- Hidden directories and imp files are discovered using Gobuster.
- Common sensitive paths like /admin /.env and /config are checked manually.
- Using Nikto, automatic vulnerability scanning can be performed.
- Http traffic is intercepted using Burp suite.Documenting findings and assessing potential risks
- Providing remediation recommendations to improve security.

5. Implementation Details:

5.1. Set Up Environment and Initial Scanning

- Kali Linux setup
- Docker deployment
- Running OWASP Juice Shop (intentionally vulnerable app)
- Verifying services and ports

5.2 Explore the Web Site

- Nmap scanning
- Curl header inspection
- Gobuster directory brute forcing
- Checking robots.txt & sitemap.xml
- Manual path probing

5.3. Analyze sensitive files and scan for vulnerabilities

- Checking .env, /config, /server-status
- Searching for secrets (API keys, tokens, passwords)
- Redacting sensitive findings
- Nikto vulnerability scanning

5.4 Manual Testing with Burp Suite

- Proxy interception
- Traffic analysis
- Login and account request manipulation

5.5 Identify Vulnerabilities

- Broken access control
- Data exposure
- Insecure APIs

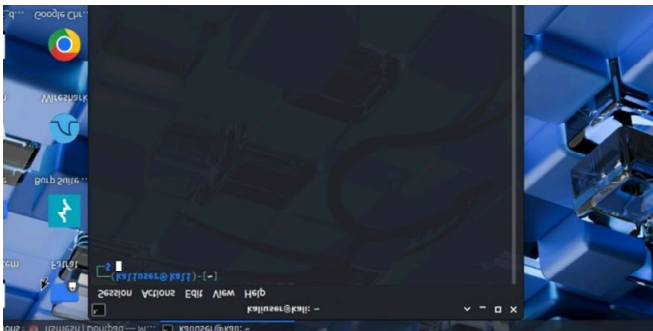
5.6 Mitigation and Retesting

- Apply fixes
- Retest vulnerabilities
- Final security review

6. Steps to be followed to achieve the results:

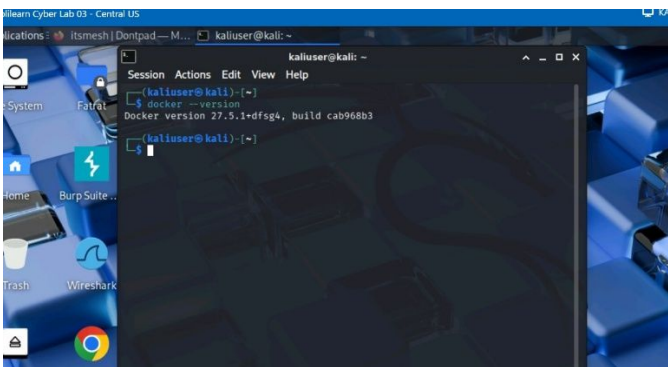
Task 1: Set Up Environment and Initial Scanning

1.1 Open Kali Linux and open the Terminal Emulator.



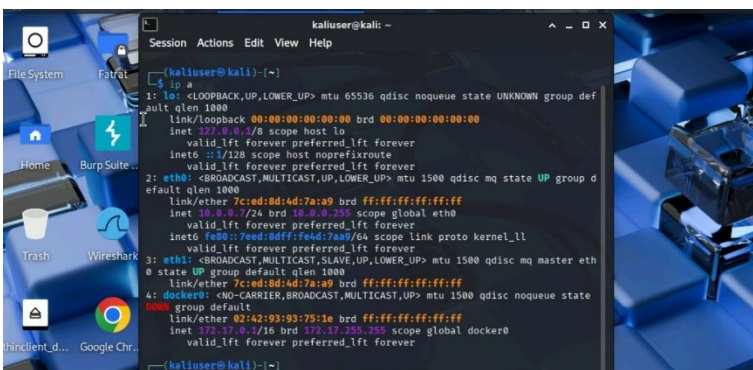
1.2. Run the following command to check the Docker version.

docker --version



1.3 Run the following command to display network interfaces and their IP addresses.

ip a



1.4. Run the following command to start the OWASP Juice Shop container:

```
sudo docker run --rm -d -p 3000:3000 --name juice-shop bkimminich/juice-shop
```

```

kaliuser@kali: ~
Session Actions Edit View Help
valid_lft forever preferred_lft forever
inet6 fe80::42:93ff:fe93:751e/64 scope link proto kernel_ll
valid_lft forever preferred_lft forever

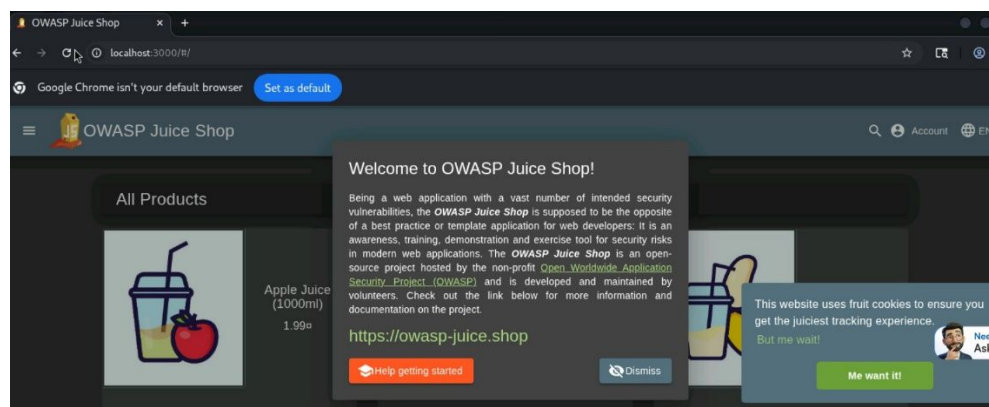
(kaliuser@kali)-[~]
$ sudo docker run --rm -d -p 3000:3000 --name juice-shop bkimminich/juice-shop
976e4ea788fc4dfa725477d962edf495ab8f05c35361d04c993bba78753b8d2c

(kaliuser@kali)-[~]
$ nmap -sV -p 21,80,3000 localhost
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-20 04:30 +0000
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000036s latency).
Other addresses for localhost (not scanned): ::1

```

1.6 Open Google Chrome and Enter the following URL.

localhost:3000/#/



1.7 Run the following command to check services and versions

nmap -sV -p 21,80,3000 localhost

[illegible]

1.8 Run the following command to check whether a process is listening on port 3000.

```
ss -tuln | grep ':3000'
```

```

SF:x20the\x20most\x20modern\x20and\x20sophisticated\x20insecure\x20web\x20
SF:application">\n\x20<meta\x20name="\x20viewport"\x20content="\x20width=
SF:device-width,\x20initial-scale=1">\n\x20<link\x20id="\x20favicon"\x20
SF:rel="\x20icon"\x20">\r(Help,2F,"HTTP/1.1\x20400\x20Bad\x20Request\r\nCon
SF:nection:\x20close\r\n\r\n")&\r(NCP,2F,"HTTP/1.1\x20400\x20Bad\x20Reques
SF:t\r\n\r\nConnection:\x20close\r\n\r\n")&\r(HTTPOptions,EA,"HTTP/1.1\x20204\
SF:x20No\x20Content\r\nAccess-Control-Allow-Origin:\x20*\r\nAccess-Control
SF:l-Allow-Methods:\x20GET,HEAD,PUT,PATCH,POST,DELETE\r\nVary:\x20Access-C
SF:ontrol-Request-Headers\r\nContent-Length:\x200\r\nDate:\x20Fri,\x2020\x20
SF:20Feb\x202026\x2004:30:48\x20GMT\r\nConnection:\x20close\r\n\r\n")&\r(RT
SF:SPRequest,EA,"HTTP/1.1\x20204\x20No\x20Content\r\nAccess-Control-Allow
SF:Origin:\x20*\r\nAccess-Control-Allow-Methods:\x20GET,HEAD,PUT,PATCH,P
SF:OST,DELETE\r\nVary:\x20Access-Control-Request-Headers\r\nContent-Length
SF::\x200\r\nDate:\x20Fri,\x2020\x20Feb\x202026\x2004:30:48\x20GMT\r\nConn
SF:ection:\x20close\r\n\r\n");

```

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/>.

Nmap done: 1 IP address (1 host up) scanned in 11.50 seconds

```

(kaliuser@kali)-[~]
$ ss -tulin | grep "3000"
tcp    LISTEN 0      4096
tcp    LISTEN 0      4096

```

<https://owasp-juice-shop>

(kaliuser@kali)-[~]

1.9 Run the following command to fetch the HTTP response headers.

```
curl -I http://localhost:3000
```

```
root@kali: ~/home/kaliuser
Session Actions Edit View Help
SF:8Feb/x2026/v2003:35:58/x20GMT\r\nConnection:\x20close\r\n\r\n}"(RTS
SF:Request_EA:"HTTP/1.1 \x20204\x20No\x20Content\r\nAccess-Control-Allow
SF:Origin:\x20*\r\nAccess-Control-Allow-Methods:\x20GET,HEAD,PUT,PATCH,PO
SF:ST_DELETE\r\nVary:\x20Access-Control-Request-Headers\r\nContent-Length:
SF:\x200\r\nDate:\x20Fri,\x2020\x20Feb\x202026\x2003:35:58\x20GMT\r\nConne
SF:ction:\x20close\r\n\r\n");

Service detection performed. Please report any incorrect results at https://n
map.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 12.15 seconds

(root@kali) ~ (/home/kaliuser)
ss -tlnl | grep ':3000'-
(root@kali) ~ (/home/kaliuser)
curl -I http://localhost:3000
<-
  Copyright (c) 2014-2026 Bjørn Kimminich & the OWASP Juice Shop contribut
ors.
    - SPDX-License-Identifier: MIT

<!doctype html>
<html lang="en" data-beasties-container>
<head>
  <meta charset="utf-8">
  <title>OWASP Juice Shop</title>
  <meta name="description" content="Probably the most modern and sophisticate
```

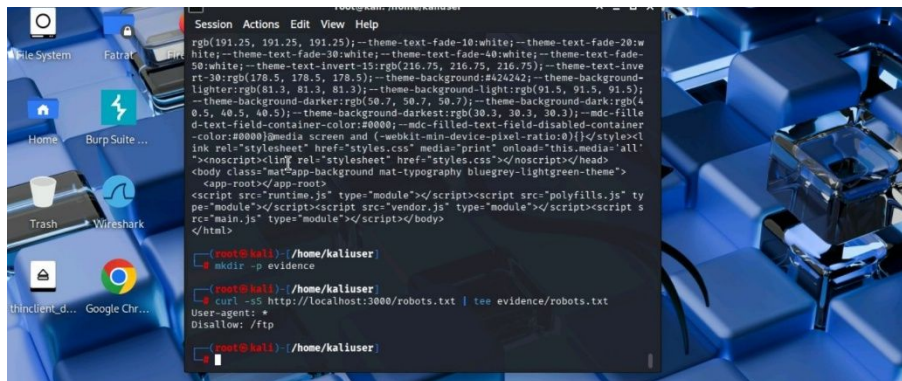
1.10 Run the following command to create the evidence directory.

```
mkdir -p evidence
```

[illegible]

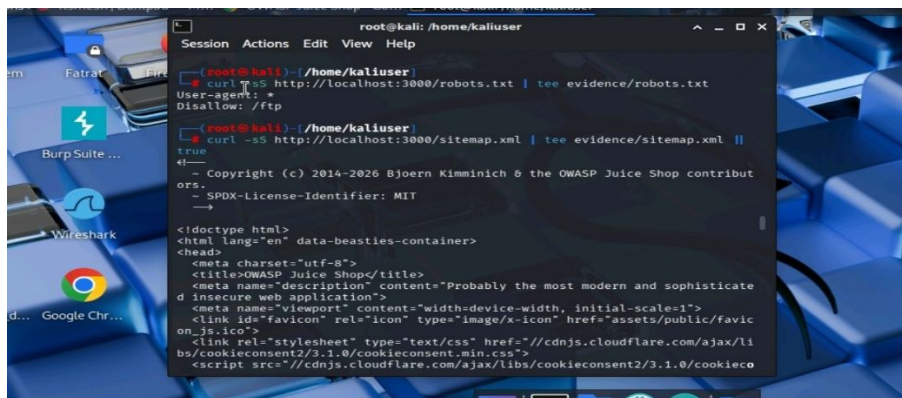
1.11 Run the following command to save robots.txt to evidence/robots.txt.

curl -sS http://localhost:3000/robots.txt | tee evidence/robots.txt

A terminal window on a Kali Linux desktop. The terminal shows the command `curl -sS http://localhost:3000/robots.txt | tee evidence/robots.txt` being executed. The output is a robots.txt file content. The desktop background shows icons for File System, Patrat, Home, Burp Suite, Trash, Wireshark, and Google Chrome.

1.12 Run the following command to save the sitemap (or homepage response at /sitemap.xml) to evidence/sitemap.xml.

curl -sS http://localhost:3000/sitemap.xml | tee evidence/sitemap.xml || true

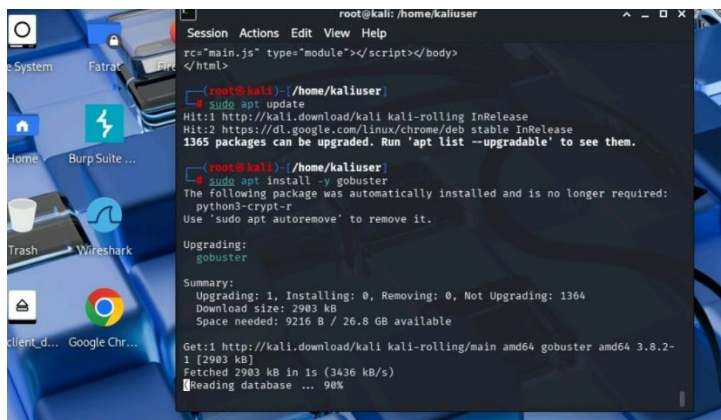
A terminal window on a Kali Linux desktop. The terminal shows the command `curl -sS http://localhost:3000/sitemap.xml | tee evidence/sitemap.xml || true` being executed. The output is an XML sitemap for OWASP Juice Shop. The desktop background shows icons for File System, Patrat, Home, Burp Suite, Trash, Wireshark, and Google Chrome.

1.13 Run the following command to update the package lists.

sudo apt update

1.14 Run the following command to install gobuster:

sudo apt install -y gobuster



```
root@kali: /home/kaliuser
Session Actions Edit View Help
rc="main.js" type="module"></script></body>
</html>

root@kali: /home/kaliuser
# sudo apt update
Hit:1 http://kali.download/kali kali-rolling InRelease
Hit:2 https://dl.google.com/linux/chrome/deb stable InRelease
1365 packages can be upgraded. Run 'apt list --upgradable' to see them.

root@kali: /home/kaliuser
# sudo apt install -y gobuster
The following package was automatically installed and is no longer required:
python3-crypt-r
Use 'sudo apt autoremove' to remove it.

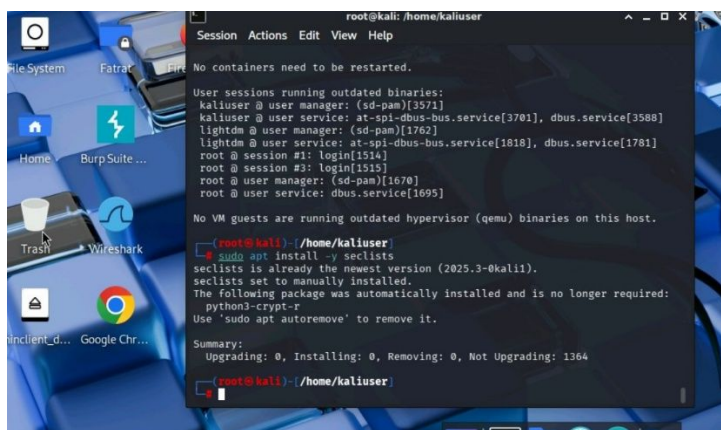
Upgrading:
gobuster

Summary:
Upgrading: 1, Installing: 0, Removing: 0, Not Upgrading: 1364
Download size: 2903 kB
Space needed: 9216 B / 26.8 GB available

Get:1 http://kali.download/kali kali-rolling/main amd64 gobuster amd64 3.8.2-1 [2903 kB]
Fetched 2903 kB in 1s (3436 kB/s)
Reading database ... 90%
```

1.15 Run the following command to install the seclists package.

sudo apt install -y seclists



```
root@kali: /home/kaliuser
Session Actions Edit View Help
No containers need to be restarted.

User sessions running outdated binaries:
kaliuser @ user manager: (sd-pam)[3571]
kaliuser @ user service: at-spi-dbus-bus.service[3701], dbus.service[3588]
lightdm @ user manager: (sd-pam)[1762]
lightdm @ user service: at-spi-dbus-bus.service[1818], dbus.service[1781]
root @ session #1: login[1514]
root @ session #3: login[1515]
root @ user manager: (sd-pam)[1670]
root @ user service: dbus.service[1695]

No VM guests are running outdated hypervisor (qemu) binaries on this host.

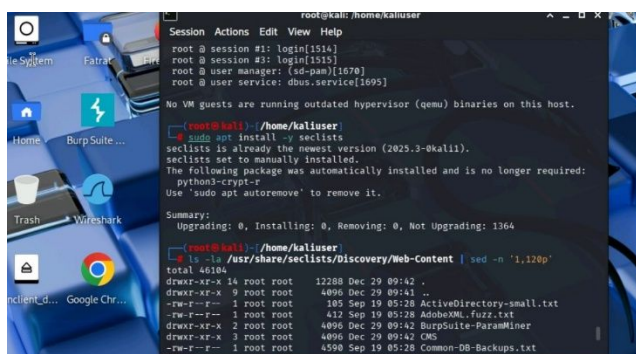
root@kali: /home/kaliuser
# sudo apt install -y seclists
seclists is already the newest version (2025.3-0kali1).
seclists set to manually installed.
The following package was automatically installed and is no longer required:
python3-crypt-r
Use 'sudo apt autoremove' to remove it.

Summary:
Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 1364

root@kali: /home/kaliuser
```

1.16 Run the following command to list the Web-Content wordlists installed by seclists:

ls -la /usr/share/seclists/Discovery/Web-Content | sed -n '1,120p'



```
root@kali: /home/kaliuser
Session Actions Edit View Help
root @ session #1: login[1514]
root @ session #1: login[1515]
root @ user manager: (sd-pam)[1670]
root @ user service: dbus.service[1695]

No VM guests are running outdated hypervisor (qemu) binaries on this host.

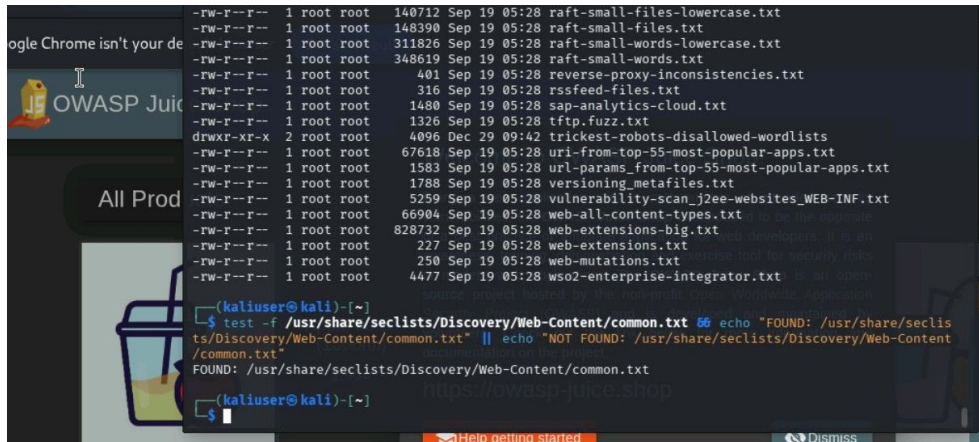
root@kali: /home/kaliuser
# sudo apt install -y seclists
seclists is already the newest version (2025.3-0kali1).
seclists set to manually installed.
The following package was automatically installed and is no longer required:
python3-crypt-r
Use 'sudo apt autoremove' to remove it.

Summary:
Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 1364

root@kali: /home/kaliuser
# ls -la /usr/share/seclists/Discovery/Web-Content | sed -n '1,120p'
total 46084
drwxr-xr-x 14 root root 12288 Dec 29 09:142 .
drwxr-xr-x 9 root root 4096 Dec 29 09:141 ..
-rw-r--r-- 1 root root 185 Sep 19 05:28 ActiveDirectory-small.txt
-rw-r--r-- 1 root root 432 Sep 19 05:28 AdobeXMP_fuzz.txt
drwxr-xr-x 2 root root 4096 Dec 29 09:142 BurpSuite-ParamMiner
drwxr-xr-x 3 root root 4096 Dec 29 09:142 CMS
-rw-r--r-- 1 root root 4590 Sep 19 05:28 Common-DB-Backups.txt
```


1.17 Run the following command to verify the common.txt wordlist exists:

```
test -f /usr/share/seclists/Discovery/Web-Content/common.txt && echo "FOUND: /usr/share/seclists/Discovery/Web-Content/common.txt" || echo "NOT FOUND: /usr/share/seclists/Discovery/Web-Content/common.txt"
```



```
-rw-r--r-- 1 root root 140712 Sep 19 05:28 raft-small-files-lowercase.txt
-rw-r--r-- 1 root root 148390 Sep 19 05:28 raft-small-files.txt
-rw-r--r-- 1 root root 311826 Sep 19 05:28 raft-small-words-lowercase.txt
-rw-r--r-- 1 root root 348619 Sep 19 05:28 raft-small-words.txt
-rw-r--r-- 1 root root 401 Sep 19 05:28 reverse-proxy-inconsistencies.txt
-rw-r--r-- 1 root root 316 Sep 19 05:28 rssfeed-files.txt
-rw-r--r-- 1 root root 1480 Sep 19 05:28 sap-analytics-cloud.txt
-rw-r--r-- 1 root root 1326 Sep 19 05:28 tftp.fuzz.txt
drwxr-xr-x 2 root root 4096 Dec 29 09:42 trickiest-robots-disallowed-wordlists
-rw-r--r-- 1 root root 67618 Sep 19 05:28 uri-from-top-55-most-popular-apps.txt
-rw-r--r-- 1 root root 1583 Sep 19 05:28 url-params_from-top-55-most-popular-apps.txt
-rw-r--r-- 1 root root 1788 Sep 19 05:28 versioning_metatypes.txt
-rw-r--r-- 1 root root 5259 Sep 19 05:28 vulnerability-scan_j2ee-websites_WEB-INF.txt
-rw-r--r-- 1 root root 66904 Sep 19 05:28 web-all-content-types.txt
-rw-r--r-- 1 root root 828732 Sep 19 05:28 web-extensions-big.txt
-rw-r--r-- 1 root root 227 Sep 19 05:28 web-extensions.txt
-rw-r--r-- 1 root root 250 Sep 19 05:28 web-mutations.txt
-rw-r--r-- 1 root root 4477 Sep 19 05:28 wso2-enterprise-integrator.txt

(kaliuser@kali)-[~]
$ test -f /usr/share/seclists/Discovery/Web-Content/common.txt && echo "FOUND: /usr/share/seclists/Discovery/Web-Content/common.txt" || echo "NOT FOUND: /usr/share/seclists/Discovery/Web-Content/common.txt"
FOUND: /usr/share/seclists/Discovery/Web-Content/common.txt

(kaliuser@kali)-[~]
```

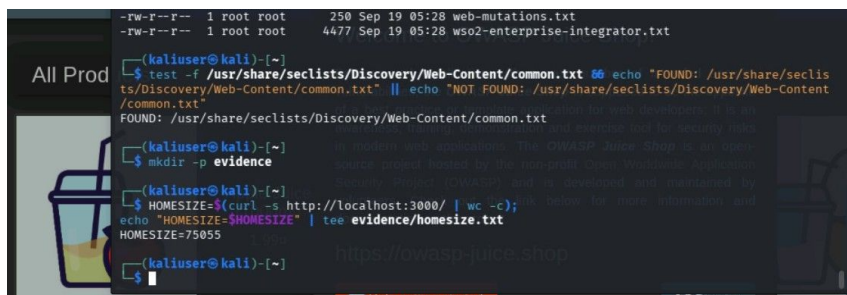
Task 2: Explore the Web Site (Enumerate directories and conduct reconnaissance)

2.1 Run the following command to create the evidence directory.

```
mkdir -p evidence
```

2.2 Run the following command to compute the canonical homepage size and save it to evidence/homesize.txt.

```
HOMESIZE=$(curl -s http://localhost:3000/ | wc -c);
echo "HOMESIZE=$HOMESIZE" | tee evidence/homesize.txt
```



```
-rw-r--r-- 1 root root 250 Sep 19 05:28 web-mutations.txt
-rw-r--r-- 1 root root 4477 Sep 19 05:28 wso2-enterprise-integrator.txt

(kaliuser@kali)-[~]
$ test -f /usr/share/seclists/Discovery/Web-Content/common.txt && echo "FOUND: /usr/share/seclists/Discovery/Web-Content/common.txt" || echo "NOT FOUND: /usr/share/seclists/Discovery/Web-Content/common.txt"
FOUND: /usr/share/seclists/Discovery/Web-Content/common.txt

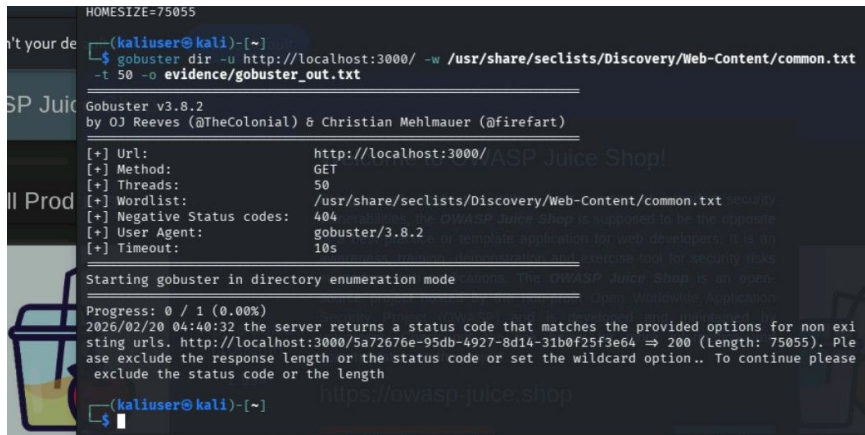
(kaliuser@kali)-[~]
$ mkdir -p evidence

(kaliuser@kali)-[~]
$ HOMESIZE=$(curl -s http://localhost:3000/ | wc -c);
echo "HOMESIZE=$HOMESIZE" | tee evidence/homesize.txt
HOMESIZE=75055

(kaliuser@kali)-[~]
```

2.3 Run the following command to start Gobuster directory enumeration and save results:

```
gobuster dir -u http://localhost:3000/ -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 50 -o evidence/gobuster_out.txt
```



```
HOMESIZE=75055
(kaliuser@kali)-[~]
$ gobuster dir -u http://localhost:3000/ -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 50 -o evidence/gobuster_out.txt

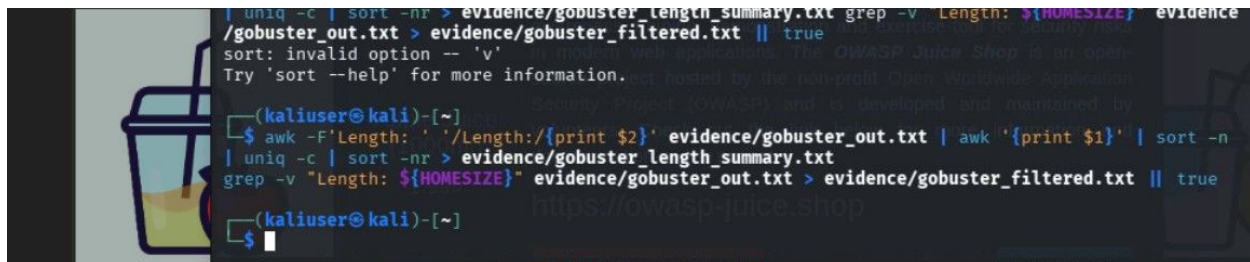
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://localhost:3000/ASP-Juice-Shop/
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode
Progress: 0 / 1 (0.00%)
2026/02/20 04:40:32 the server returns a status code that matches the provided options for non existing urls. http://localhost:3000/5a72676e-95db-4927-8d14-31b0f25f3e64 => 200 (Length: 75055). Please exclude the response length or the status code or set the wildcard option.. To continue please exclude the status code or the length
(kaliuser@kali)-[~]
$
```

2.4 Run the following command to create a Gobuster length summary and filter out SPA-length.

```
awk -F'Length: ' '/Length:/{print $2}' evidence/gobuster_out.txt | awk '{print $1}' | sort -n | uniq -c | sort -nr > evidence/gobuster_length_summary.txt grep -v "Length: ${HOMESIZE}" evidence/gobuster_out.txt > evidence/gobuster_filtered.txt || true
```



```
(kaliuser@kali)-[~]
$ awk -F'Length: ' '/Length:/{print $2}' evidence/gobuster_out.txt | awk '{print $1}' | sort -n | uniq -c | sort -nr > evidence/gobuster_length_summary.txt
$ grep -v "Length: ${HOMESIZE}" evidence/gobuster_out.txt > evidence/gobuster_filtered.txt || true
(kaliuser@kali)-[~]
$
```

2.5 Run the following command to probe common high-value paths and save headers + page heads to evidence.

```
for p in ftp admin uploads backup config .env server-status; do
  echo "=== /$p ===" | tee -a evidence/manual_path_checks.txt
  curl -s -I "http://localhost:3000/$p" 2>/dev/null | sed -n '1,10p' | tee -a evidence/manual_path_checks.txt
  curl -s "http://localhost:3000/$p" | head -n 200 > evidence/path_${p}_head.html || true
done
```

```

(kaliuser@kali)-[~]
$ for p in ftp admin uploads backup config .env server-status; do
  echo "$p" | tee -a evidence/manual_path_checks.txt
  curl -s -I 'http://localhost:3000/$p' 2>/dev/null | sed -n '1,10p' | tee -a evidence/manual_path_checks.txt
  curl -s 'http://localhost:3000/$p' | head -n 200 > evidence/path_${p}_head.html || true
done
/ftp
/admin
/uploads
/backup
/config
/.env
/server-status

```

2.6 Run the following command to search saved pages for likely secrets and save matches:

**grep -iE 'flag|key|secret|password|token|credential|api|aws|passwd' evidence/*.html
> evidence/secret_search_results.txt || true**

```

(kaliuser@kali)-[~]
$ grep -iE 'flag|key|secret|password|token|credential|api|aws|passwd' evidence/*.html > evidence/secret_search_results.txt || true

```

2.7 Run the following command to show HOMESIZE, tail of gobuster_filtered, and manual path checks.

echo "--- HOMESIZE -- "; cat evidence/homesize.txt echo; echo "---- tail gobuster_filtered -- "; tail -n 20 evidence/gobuster_filtered.txt echo; echo "---- manual path checks - "; sed -n '1,240p' evidence/manual_path_checks.txt

```

(kaliuser@kali)-[~]
$ echo "--- HOMESIZE -- "; cat evidence/homesize.txt echo; echo "---- tail gobuster_filtered -- "; tail -n 20 evidence/gobuster_filtered.txt echo; echo "---- manual path checks - "; sed -n '1,240p' evidence/manual_path_checks.txt
--- HOMESIZE --
HOMESIZE=75055
cat: echo: No such file or directory
tail gobuster_filtered --
tail: cannot open 'echo' for reading: No such file or directory
manual path checks -
/ftp
/admin
/uploads
/backup

```

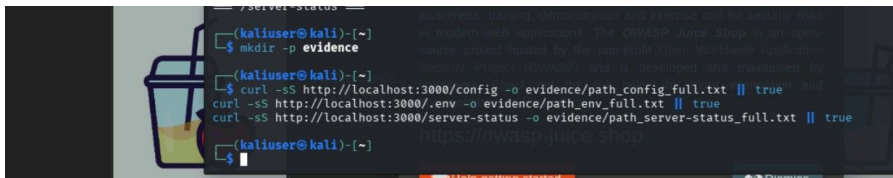
Task 3: Analyze sensitive files and scan for vulnerabilities

3.1 Run the following command to create the evidence directory:

```
mkdir -p evidence
```

3.2 Run the following command to save /config, /.env, and /server-status to evidence.

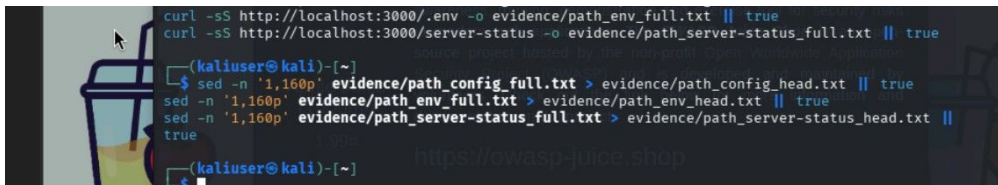
```
curl -sS http://localhost:3000/config -o evidence/path_config_full.txt || true
curl -sS http://localhost:3000/.env -o evidence/path_env_full.txt || true
curl -sS http://localhost:3000/server-status -o evidence/path_server-status_full.txt || true
```

A terminal window with a dark background and a coffee cup icon on the left. The terminal shows the following commands and their outputs:

```
(kaliuser@kali)-[~]
$ mkdir -p evidence
(kaliuser@kali)-[~]
$ curl -sS http://localhost:3000/config -o evidence/path_config_full.txt || true
curl -sS http://localhost:3000/.env -o evidence/path_env_full.txt || true
curl -sS http://localhost:3000/server-status -o evidence/path_server-status_full.txt || true
(kaliuser@kali)-[~]
```

3.3 Run the following command to create short head previews for the saved full pages.

```
sed -n '1,160p' evidence/path_config_full.txt > evidence/path_config_head.txt || true
sed -n '1,160p' evidence/path_env_full.txt > evidence/path_env_head.txt || true
sed -n '1,160p' evidence/path_server-status_full.txt > evidence/path_server-status_head.txt || true
```

A terminal window with a dark background and a coffee cup icon on the left. The terminal shows the following commands and their outputs:

```
(kaliuser@kali)-[~]
$ sed -n '1,160p' evidence/path_config_full.txt > evidence/path_config_head.txt || true
sed -n '1,160p' evidence/path_env_full.txt > evidence/path_env_head.txt || true
sed -n '1,160p' evidence/path_server-status_full.txt > evidence/path_server-status_head.txt || true
(kaliuser@kali)-[~]
```

3.4 Run the following command to search saved path files for likely secrets(Passwords) and save matches.

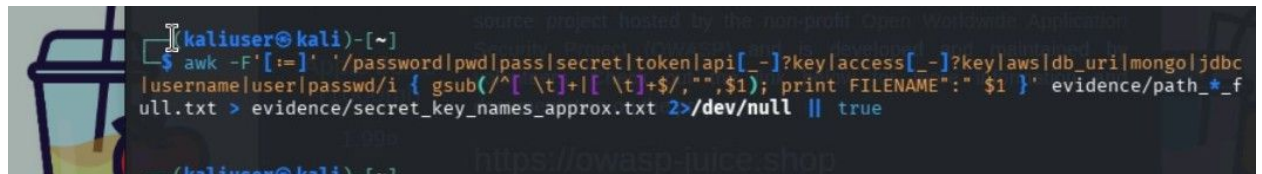
```
grep -iEnH 'password|pwd|pass|secret|token|api[_-]?key|access[_-]?key|aws|db_uri|mongo|db|username|user|passwd' evidence/path_*.full.txt > evidence/secret_search_results.txt || true
```



A terminal window showing the execution of the grep command. The prompt is (kaliuser@kali)-[~]. The command is: `grep -iEnH 'password|pwd|pass|secret|token|api[_-]?key|access[_-]?key|aws|db_uri|mongo|db|username|user|passwd' evidence/path_*.full.txt > evidence/secret_search_results.txt || true`. The output shows the command being executed and the file being created.

3.5 Run the following command to extract approximate key names and save.

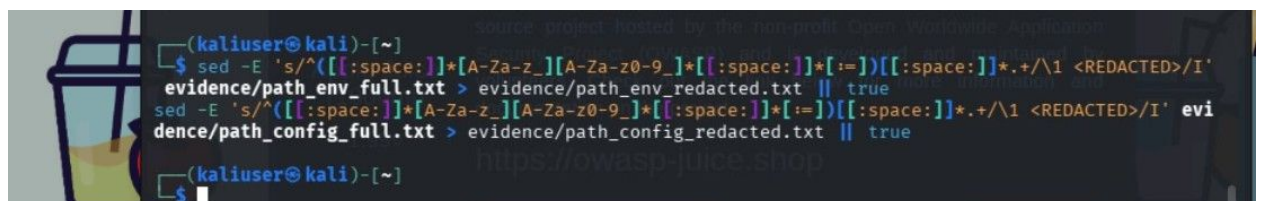
```
awk -F'[:=]' '/password|pwd|pass|secret|token|api[_-]?key|access[_-]?key|aws|db_uri|mongo|jdbc|username|user|passwd/i { gsub(/^[ \t]+|[ \t]+$/, "", $1); print FILENAME": " $1 }' evidence/path_*.full.txt > evidence/secret_key_names_approx.txt 2>/dev/null || true
```



A terminal window showing the execution of the awk command. The prompt is (kaliuser@kali)-[~]. The command is: `awk -F'[:=]' '/password|pwd|pass|secret|token|api[_-]?key|access[_-]?key|aws|db_uri|mongo|jdbc|username|user|passwd/i { gsub(/^[ \t]+|[ \t]+$/, "", $1); print FILENAME": " $1 }' evidence/path_*.full.txt > evidence/secret_key_names_approx.txt 2>/dev/null || true`. The output shows the command being executed and the file being created.

3.6 Run the following command to create redacted copies of the saved env/config files.

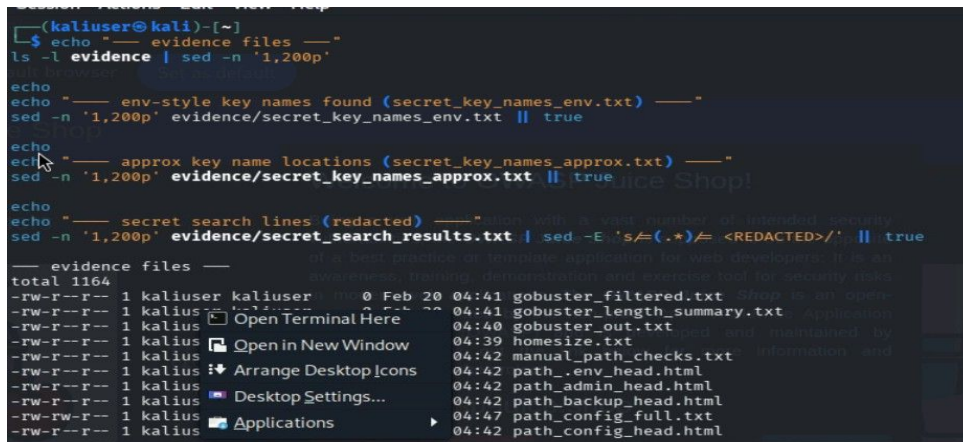
```
sed -E 's/^([:space:])*[A-Za-z_][A-Za-z0-9]*[:space:]*[:=][:space:]]*./\1 <REDACTED>/I' evidence/path_env_full.txt > evidence/path_env_redacted.txt || true
sed -E 's/^([:space:])*[A-Za-z_][A-Za-z0-9]*[:space:]*[:=][:space:]]*./\1 <REDACTED>/I' evidence/path_config_full.txt > evidence/path_config_redacted.txt || true
```



A terminal window showing the execution of the sed commands. The prompt is (kaliuser@kali)-[~]. The first command is: `sed -E 's/^([:space:])*[A-Za-z_][A-Za-z0-9]*[:space:]*[:=][:space:]]*./\1 <REDACTED>/I' evidence/path_env_full.txt > evidence/path_env_redacted.txt || true`. The second command is: `sed -E 's/^([:space:])*[A-Za-z_][A-Za-z0-9]*[:space:]*[:=][:space:]]*./\1 <REDACTED>/I' evidence/path_config_full.txt > evidence/path_config_redacted.txt || true`. The output shows the commands being executed and the files being created.

3.7 Run the following command to list evidence/ and print short secret-search summaries:

```
echo "--- evidence files--- "; ls -l evidence | sed -n '1,200p'
echo; echo "---- env-style key names found (secret_key_names_env.txt)---"; sed -n
'1,200p'
evidence/secret_key_names_env.txt || true
echo; echo "---- approx key name locations (secret_key_names_approx.txt) - "; sed -
n '1,200p'
evidence/secret_key_names_approx.txt || true
echo; echo "---- secret search lines (redacted) -"; sed -n '1,200p'
evidence/secret_search_results.txt | sed -E 's/(.*)= <REDACTED>/' || true
```



```
(kaliuser@kali)-[~]
└─$ echo "--- evidence files ---"
ls -l evidence | sed -n '1,200p'

echo
echo "---- env-style key names found (secret_key_names_env.txt) ----"
sed -n '1,200p' evidence/secret_key_names_env.txt || true

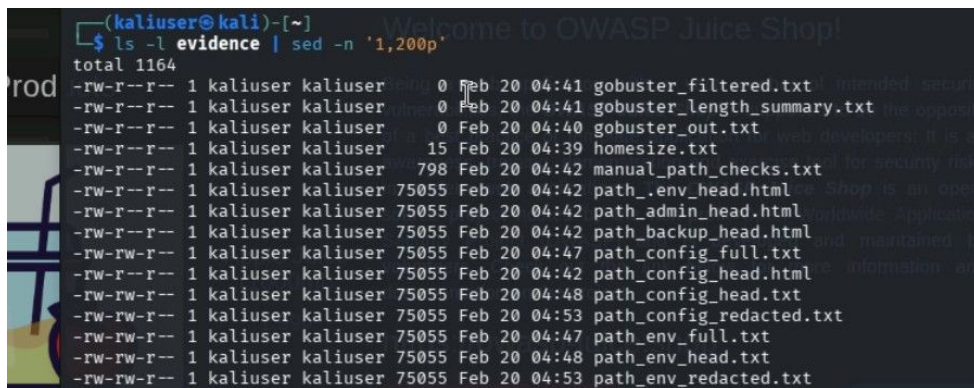
echo
echo "---- approx key name locations (secret_key_names_approx.txt) ----"
sed -n '1,200p' evidence/secret_key_names_approx.txt || true

echo
echo "---- secret search lines (redacted) ----"
sed -n '1,200p' evidence/secret_search_results.txt | sed -E 's/(.*)= <REDACTED>/' || true

--- evidence files ---
total 1164
-rw-r--r-- 1 kaliuser kaliuser 0 Feb 20 04:41 gobuster_filtered.txt
-rw-r--r-- 1 kaliuser kaliuser 0 Feb 20 04:41 gobuster_length_summary.txt
-rw-r--r-- 1 kaliuser kaliuser 0 Feb 20 04:40 gobuster_out.txt
-rw-r--r-- 1 kaliuser kaliuser 0 Feb 20 04:39 homesize.txt
-rw-r--r-- 1 kaliuser kaliuser 0 Feb 20 04:42 manual_path_checks.txt
-rw-r--r-- 1 kaliuser kaliuser 0 Feb 20 04:42 path_env_head.html
-rw-r--r-- 1 kaliuser kaliuser 0 Feb 20 04:42 path_admin_head.html
-rw-r--r-- 1 kaliuser kaliuser 0 Feb 20 04:42 path_backup_head.html
-rw-r--r-- 1 kaliuser kaliuser 0 Feb 20 04:47 path_config_full.txt
-rw-r--r-- 1 kaliuser kaliuser 0 Feb 20 04:42 path_config_head.html
```

3.8 Run the following command to list evidence/ and print secret-search summaries.

```
ls -l evidence | sed -n '1,200p'
```

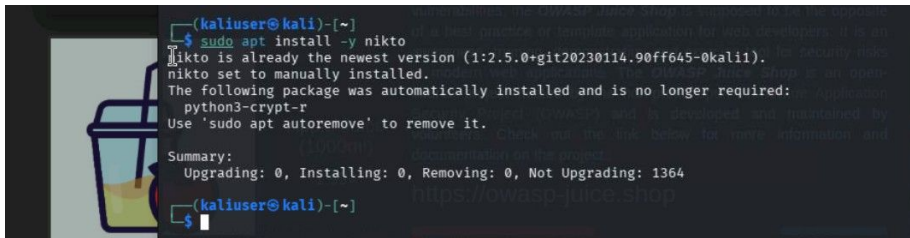


```
(kaliuser@kali)-[~]
└─$ ls -l evidence | sed -n '1,200p'

total 1164
-rw-r--r-- 1 kaliuser kaliuser 0 Feb 20 04:41 gobuster_filtered.txt
-rw-r--r-- 1 kaliuser kaliuser 0 Feb 20 04:41 gobuster_length_summary.txt
-rw-r--r-- 1 kaliuser kaliuser 0 Feb 20 04:40 gobuster_out.txt
-rw-r--r-- 1 kaliuser kaliuser 0 Feb 20 04:39 homesize.txt
-rw-r--r-- 1 kaliuser kaliuser 798 Feb 20 04:42 manual_path_checks.txt
-rw-r--r-- 1 kaliuser kaliuser 75055 Feb 20 04:42 path_env_head.html
-rw-r--r-- 1 kaliuser kaliuser 75055 Feb 20 04:42 path_admin_head.html
-rw-r--r-- 1 kaliuser kaliuser 75055 Feb 20 04:42 path_backup_head.html
-rw-r--r-- 1 kaliuser kaliuser 75055 Feb 20 04:47 path_config_full.txt
-rw-r--r-- 1 kaliuser kaliuser 75055 Feb 20 04:42 path_config_head.html
-rw-r--r-- 1 kaliuser kaliuser 75055 Feb 20 04:48 path_config_head.txt
-rw-r--r-- 1 kaliuser kaliuser 75055 Feb 20 04:53 path_config_redacted.txt
-rw-r--r-- 1 kaliuser kaliuser 75055 Feb 20 04:47 path_env_full.txt
-rw-r--r-- 1 kaliuser kaliuser 75055 Feb 20 04:48 path_env_head.txt
-rw-r--r-- 1 kaliuser kaliuser 75055 Feb 20 04:53 path_env_redacted.txt
```

3.9 Run the following command to install Nikto.

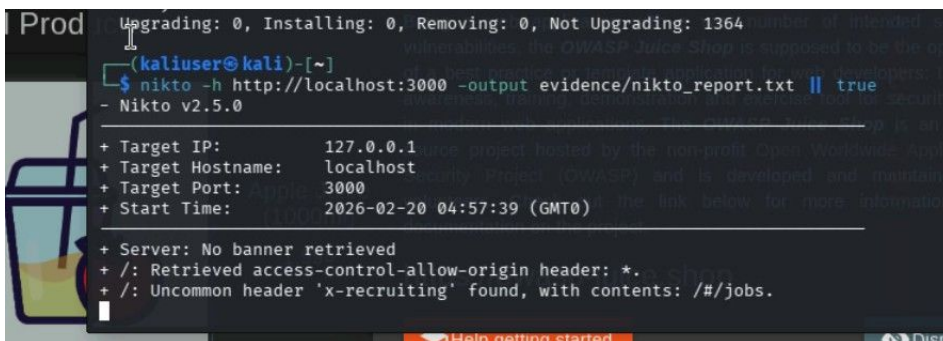
sudo apt install -y nikto



```
(kaliuser@kali)-[~]
$ sudo apt install -y nikto
Nikto is already the newest version (1:2.5.0+git20230114.90ff645-0kali1).
nikto set to manually installed.
The following package was automatically installed and is no longer required:
python3-crypt-r
Use 'sudo apt autoremove' to remove it.
Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 1364
(kaliuser@kali)-[~]
$
```

3.10 Run the following command to scan the web app with Nikto and save the report.

nikto -h http://localhost:3000 -output evidence/nikto_report.txt || true



```
Prod Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 1364
(kaliuser@kali)-[~]
$ nikto -h http://localhost:3000 -output evidence/nikto_report.txt || true
- Nikto v2.5.0

+ Target IP: 127.0.0.1
+ Target Hostname: localhost
+ Target Port: 3000
+ Start Time: 2026-02-20 04:57:39 (GMT0)

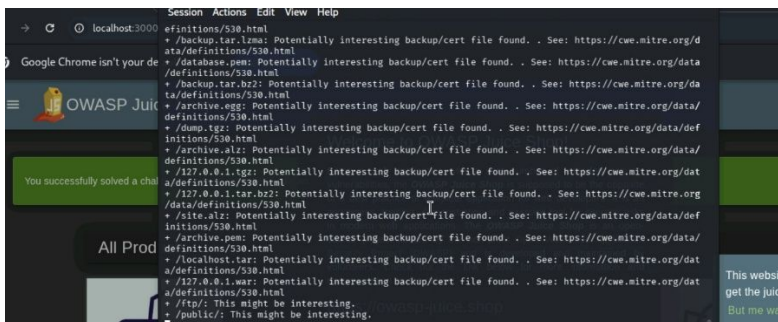
+ Server: No banner retrieved
+ /: Retrieved access-control-allow-origin header: *.
+ /: Uncommon header 'x-recruiting' found, with contents: /#/jobs.
```

3.11 Run the following command to show the saved Nikto report file:

ls -lh evidence/nikto_report.txt

3.12 Run the following command to print the first 120 lines of the Nikto report:

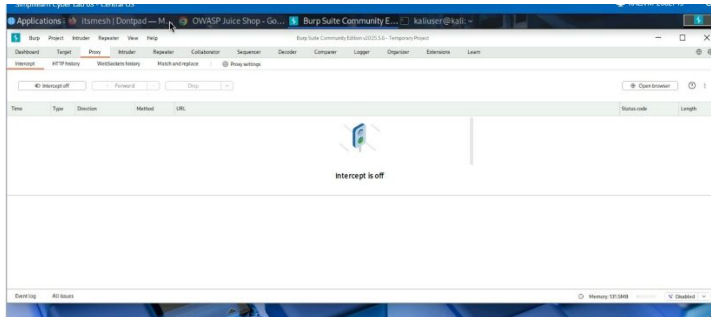
sed -n '1,120p' evidence/nikto_report.txt



```
Session Actions Edit View Help
→ localhost:3000 definitions/530.html
* /backup.tar.gz: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
* /database.pem: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
* /backup.tar.bz2: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
* /archive.egg: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
* /dump.tgz: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
* /archive.als: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
* /127.0.0.1.tgz: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
* /127.0.0.1.tar.bz2: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
* /archive.pem: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
* /localhost.tar: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
* /127.0.0.1.war: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
* /site.als: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
* /ftp/: This might be interesting.
* /public/: This might be interesting.
```

Task 4: Configure Burp Suite interception and manual traffic analysis

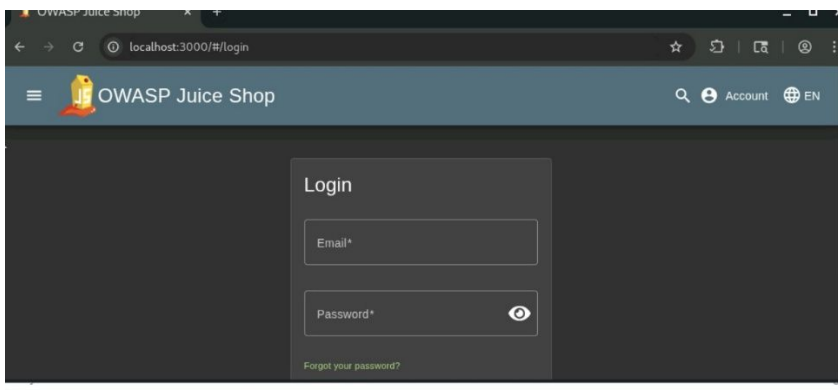
4.1 Open the Burp Suite and Click NextClick Start Burp The Burp Suite interface opens, as shown in the following image:



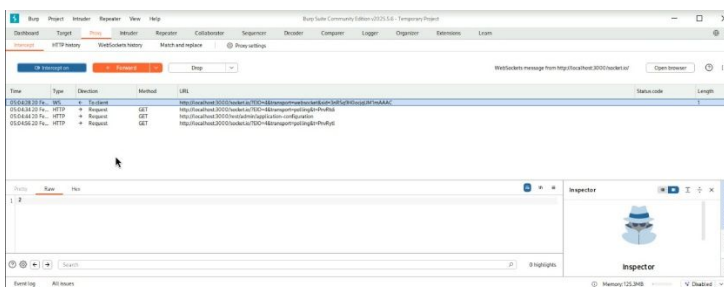
4.2 Click Proxy 4.4 Click Open browser and In the browser, enter the following URL.

<http://localhost:3000/>

4.3 Navigate back to Burp Suite and click Intercept on and Go back to the browser and click Account



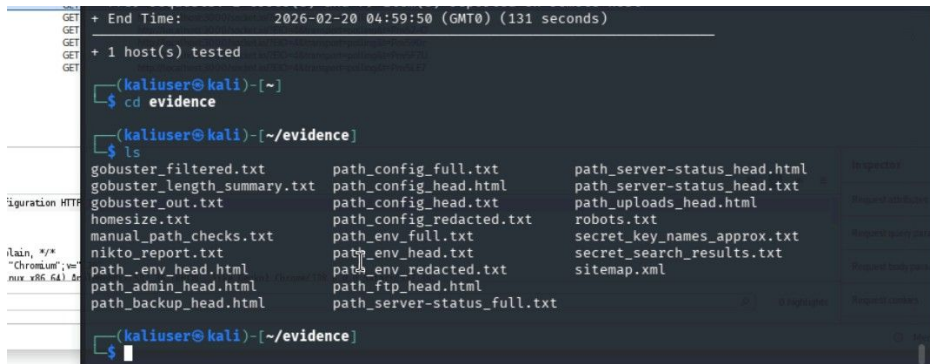
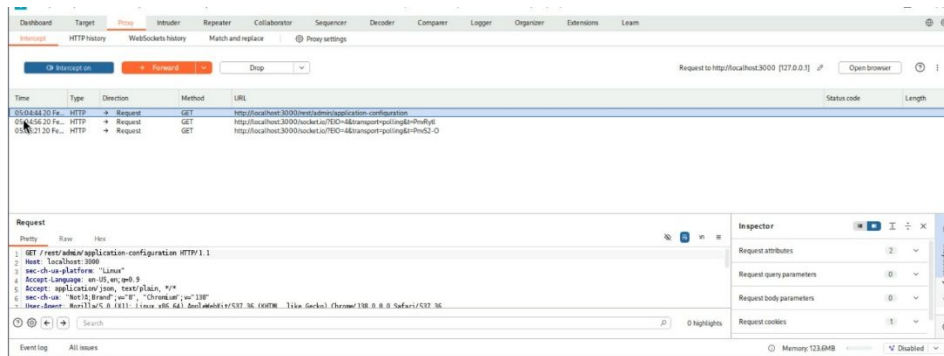
4.4 Navigate back to Burp Suite 4.9 Click Forward



Output:

The assessment identified the following issues:

- Exposed sensitive paths such as /ftp and /config
- Misconfigured HTTP headers
- Potential secret information in configuration files
- Open application port 3000
- Insecure access control mechanisms
- Weak authentication handling
- Insecure API endpoints



Conclusion:

This project successfully demonstrated the importance of conducting security assessments before deploying a web application. Using OWASP Juice Shop in a Docker environment on Kali Linux, multiple vulnerabilities were identified, including exposed files, insecure configurations, weak access controls, and potential data exposure risks.

The findings emphasize the need for:

- Secure configuration management
- Proper input validation
- Hardened HTTP security headers
- Strict access control implementation
- Regular vulnerability scanning

References:

1. Application Security, Vulnerability Management, and Cyber Resilience course CEP session by Walter

Thank You